
"Navigating Network Security Through Network Protocols, Ports, NetStat, and Simulation of SQL Injection "

By: Mark Plowright

Agenda

Agenda

Our agenda includes:

- Attacks and Security Of Networks
- Essential Network Protocols
- TCP 3-Way Handshake View
- Ports IP Address
- SQL Injection Simulation
- Netstat command prompt
- Vulnerability to SQL Injection Test
- SQL Logic OR Payload
- SQL Comment Payload
- ---

References Conclusion and Q&A."

Attacks of Network Security

Common Attacks in Network Security

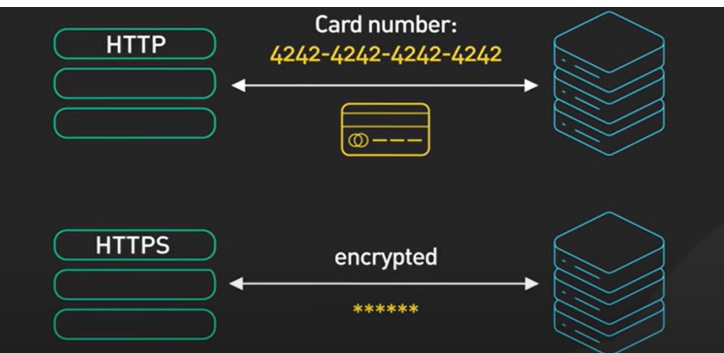
- 1. Man-in-the-Middle (MitM) Attack: Attacker intercepts communication between two parties to eavesdrop or manipulate. Example: Rogue Wi-Fi hotspot in public place intercepts user traffic to steal login credentials. **Intercepting TCP Handshake**
- 2. Phishing Attack: Attacker sends fraudulent emails or messages to trick recipients into revealing sensitive information. Example: Fake bank email requests login credentials via a deceptive link.
- 3. SQL Injection Attack: Attacker injects malicious SQL code into web app input fields to manipulate backend database. Example: Exploiting login form vulnerability with crafted SQL commands to bypass authentication and access database.

Essential Network Protocols

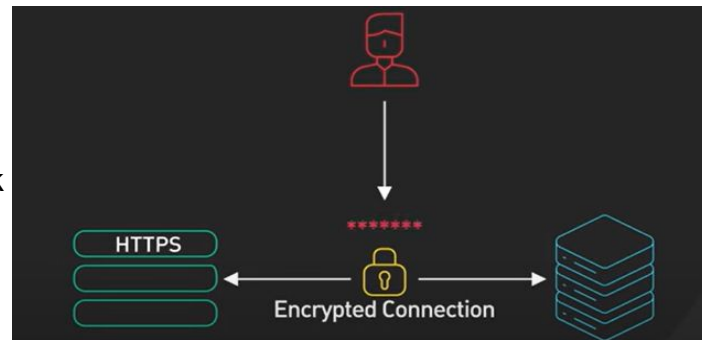
Transmission Control Protocol: TCP is a set of rules that govern how data flows between different communication systems slower than UDP due to 3-way Handshake to make sure data packets are received to client user. Examples: email receiving, texting, and browsing the web

User Data Protocol : UDP does not use Handshake it does not care if some data are not received by client from server. Speed over Accuracy. Example: Video Calls, Live TV, streaming

Hypertext Transfer Protocol: HTTP/HTTPS Port 80 and 443 **TSL Protocol :** Transport Socket Layer for encryption using cryptography to protect sensitive data; credit card, login info etc.



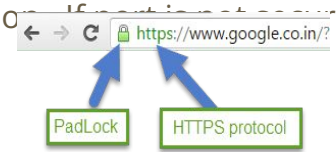
Man-in-the-Middle (MitM) Attack



(MitM) Attack Unsuccessful

IP Address and Ports HTTP 80

- Port is not a physical connection, it's a logical connection that is used by programs and services to exchange information.
- It determines which program or service on a computer or server that is going to be used. Whether that is pulling up a web page using port 80 HTTP, 443 HTTPS, or accessing email and so on. If a port is mentioned in URL, it will indicate it showing
- Ports have a unique number that identifies them. Ranges from 0 - 65535.
- An IP address is a numeric address. It's an identifier for a computer or device on a network, shows where device is located. Every device must have an IP address for communication purposes an IP address and a port number work together to exchange data on a network.



A port is always associated with an IP address. An IP address determines the location of that server.

IP ADDRESS

66.94.34.13:21
12.34.56.78:25
75.12.212.44:80
43.14.250.12:443

PORT

43.14.250.12

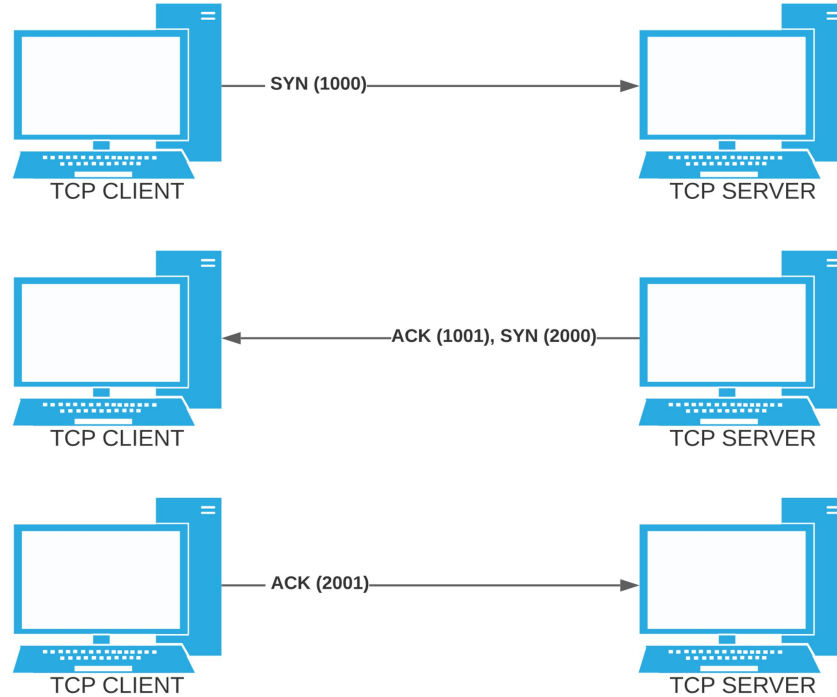
A port number determines which service or program on that server it wants to use.

21	25	143
22	53	443
23	80	1527

215.114.85.17: 80 or 443 if secure

A diagram showing a server rack on the right with various services labeled: Web page, FTP, Email, and GOOGLE. A blue line connects the server rack to a desktop computer on the left. Below the desktop computer is a web browser window showing the URL 'http://www.google.com'. A yellow arrow points from the desktop computer to the browser window.

TCP 3-Way Handshake View



3-Way Handshake

SQL Injection Simulation

Browser address bar: altoro.testfire.net/login.jsp (Not secure)

Navigation links: Cyber Applications, Cyber Training, Skill Section - Zety, Methodist Universi..., Green & Gold Dinin..., NCDMV Online Ap..., Tournaments - Nor..., Clubs & Organizati..., Introduction to Co...

Sign In | Contact Us | Feedback | Search [] Go

AltoroMutual

DEMO SITE ONLY

ONLINE BANKING LOGIN

PERSONAL

- PERSONAL
 - Deposit Product
 - Checking
 - Loan Products
 - Cards
 - Investments & Insurance
 - Other Services
- SMALL BUSINESS
 - Deposit Products
 - Lending Services
 - Cards
 - Insurance
 - Retirement
 - Other Services
- INSIDE ALTORO MUTUAL
 - About Us
 - Contact Us
 - Locations
 - Investor Relations
 - Press Room
 - Careers
 - Subscribe

Online Banking Login

Username:

Password:

Login

HTTP Port 80

Privacy Policy | Security Statement | Server Status Check | REST API | © 2024 Altoro Mutual, Inc.

This web application is open source! Get your copy from GitHub and take advantage of advanced features

The AltoroJ website is published by HCL Technologies, Ltd. for the sole purpose of demonstrating the effectiveness of HCL products in detecting web application vulnerabilities and website defects. This site is not a real banking site. Similarities, if any, to third party products and/or websites are purely coincidental. This site is provided "as is" without warranty of any kind, either express or implied. HCL does not assume any risk in relation to your use of this website. For more information, please go to <https://www.hcl-software.com/appscan/>.

Copyright © 2008, 2017, IBM Corporation, All rights reserved. Copyright © 2017, 2024, HCL Technologies, Ltd., All rights reserved.

The screenshot shows a Windows desktop with a Command Prompt window open. The Command Prompt displays the output of the 'netstat -n' command, showing active connections to various IP addresses. An orange arrow points from the text 'HTTP Port 80' to the 'TIME_WAIT' state in the taskbar.

Command Prompt Output:

```
Microsoft Windows [Version 10.0.22631.3447]
(c) Microsoft Corporation. All rights reserved.

C:\Users\mlppl>netstat -n
'netstat -n' is not recognized as an internal or external command,
operable program or batch file.

C:\Users\mlppl>netstat -n

Active Connections

Proto Local Address Foreign Address State
TCP 127.0.0.1:5354 127.0.0.1:49679 ESTABLISHED
TCP 127.0.0.1:5354 127.0.0.1:49680 ESTABLISHED
TCP 127.0.0.1:49671 127.0.0.1:49672 ESTABLISHED
TCP 127.0.0.1:49672 127.0.0.1:49671 ESTABLISHED
TCP 127.0.0.1:49673 127.0.0.1:49674 ESTABLISHED
TCP 127.0.0.1:49674 127.0.0.1:49673 ESTABLISHED
TCP 127.0.0.1:49679 127.0.0.1:5354 ESTABLISHED
TCP 127.0.0.1:49680 127.0.0.1:5354 ESTABLISHED
TCP 127.0.0.1:58527 127.0.0.1:58529 ESTABLISHED
TCP 127.0.0.1:58529 127.0.0.1:58527 ESTABLISHED
TCP 127.0.0.1:58534 127.0.0.1:58535 ESTABLISHED
TCP 127.0.0.1:58535 127.0.0.1:58534 ESTABLISHED
TCP 127.0.0.1:56939 127.0.0.1:56939 ESTABLISHED
TCP 127.0.0.1:56939 127.0.0.1:56938 ESTABLISHED
TCP 172.28.0.183:7680 172.28.0.183:65144 TIME_WAIT
TCP 172.28.0.183:7680 172.22.2.99:51380 TIME_WAIT
TCP 172.28.0.183:7680 172.22.2.99:51395 TIME_WAIT
TCP 172.28.0.183:49415 20.7.2.167:443 ESTABLISHED
TCP 172.28.0.183:50394 52.123.190.76:443 ESTABLISHED
TCP 172.28.0.183:50399 52.108.216.86:443 ESTABLISHED
TCP 172.28.0.183:50591 52.123.190.77:443 ESTABLISHED
TCP 172.28.0.183:50943 52.96.119.82:443 ESTABLISHED
TCP 172.28.0.183:51651 104.18.39.102:443 ESTABLISHED
TCP 172.28.0.183:52696 52.111.230.11:443 ESTABLISHED
TCP 172.28.0.183:52686 52.108.8.12:443 ESTABLISHED
TCP 172.28.0.183:52691 20.127.250.238:443 ESTABLISHED
TCP 172.28.0.183:52872 142.251.111.188:5228 ESTABLISHED
TCP 172.28.0.183:52898 13.107.42.10:443 ESTABLISHED
```

Taskbar:

The taskbar shows several icons, including a clock, a search bar, and several application icons. An orange arrow points from the text 'HTTP Port 80' to the 'TIME_WAIT' state in the taskbar.

SQL Injection Simulation

Username	admin
Password	password123
Login	

Username	Password
admin	s3cret123
linus	screwdriver
austin	bruh123
cameron	ufcufcufc123

```
SELECT * FROM users WHERE username ='admin' AND password='password123'
```

SQL Injection Simulation

The aim of SQL Injection is to add more query to manipulate the already present query commands.

Anything inside ' ' is a string datatype

The rest is SQL query



```
SELECT * FROM users WHERE username ='admin' AND password='password123'
```

Vulnerability to SQL Injection Test

AltoroMutual

Sign In | Contact Us | Feedback | Search

ONLINE BANKING LOGIN

PERSONAL

SMALL BUSINESS

INSIDE ALTORO MUTUAL

Online Banking Login

Syntax error: Encountered "123456765432" at line 1, column 67.

Username: admin'

Password:

Login

Privacy Policy | Security Statement | Server Status Check | REST API | © 2024 Altoro Mutual, Inc.

This web application is open source! Get your copy from GitHub and take advantage of advanced features

The AltoroJ website is published by HCL Technologies, Ltd. for the sole purpose of demonstrating the effectiveness of HCL products in detecting web application vulnerabilities and website defects. This site is not a real banking site. Similarities, if any, to the property products and/or websites are purely coincidental. This site is provided "as is" without warranty of any kind, either express or implied. HCL does not assume any risk in relation to your use of this website. For more information, please go to <https://www.hcl-software.com/altoroj/>.

Copyright © 2008, 2017, IBM Corporation, All rights reserved. Copyright © 2017, 2024, HCL Technologies, Ltd., All rights reserved.

Plain Text
HTTP NOT (S)

string hanging '

```
SELECT * FROM users WHERE username = 'admin' AND password='password123'
```

SQL Logic AND/OR operators Payload OR = '1'='1'

Query is saying Username AND Password...MUST match the database in backend.
If different it will always = False

SQL Injection is to find a way for Query to always = True...INJECT more SQL Query to manipulate it.

Username

admin' OR '1'='1

Password

password123

Login

```
SELECT * FROM users WHERE username = 'admin' OR '1'='1' AND password='password123'
```

SQL Payload --[] comment

Injecting with a comment used in SQL which is -- with a space manipulates SQL code to ignore the code in purple

Now it asks the database if the username is admin? No need for password since the query has an injected payload tricking it that it is a comment.

Username

admin'--

Password

password123

Login

```
SELECT * FROM users WHERE username = 'admin' -- 'AND password='password123'
```

References Q&A

<https://tryhackme.com/r/room/introtooffensivesecurity>

<http://aloro.testfire.net/login.jsp>

<https://tryhackme.com/r/room/introtooffensivesecurity>

<https://www.crowdstrike.com/cybersecurity-101/sql-injection/>